

Guidelines For Auditing & Conducting Cybersecurity Risk Assessment for Critical Information Infrastructure



TABLE OF CONTENTS

1 INTRODUCTION	2
1.1 Importance of Cybersecurity Risk Assessment	2
1.2 Common Problems Observed	2
2 PURPOSE, AUDIENCE & SCOPE	4
2.1 Purpose of Document	4
2.2 Audience	4
2.3 Scope	4
3 AUDITOR APPROVAL	5
4 AUDIT EXPECTATION	5
4.1 Principle of Auditing	6
4.2 Audit Objective	7
4.3 Audit Scope	7
4.4 Audit Approach	7
4.5 Audit Finding	8
4.6 Audit Conclusion	8
4.7 Audit Report Format	9
5 ESTABLISH RISK CONTEXT	10
5.1 Define Risk	10
5.2 Determine Risk Tolerance	11
5.3 Define Roles and Responsibilities	12
6 CONDUCT RISK ASSESSMENT	13
6.1 Step 1: Risk Identification	13
6.2 Step 2: Risk Analysis	16
6.3 Step 3: Risk Evaluation	21
7 RESPOND TO RISKS	23
7.1 Types of Risk Response Options	23
7.2 Choosing the Appropriate Risk Response Actions	23
8 TERMS AND DEFINITIONS	24
ANNEX	25
REFERENCES	26

1 INTRODUCTION

Under section 83(3) of the CYBERSECURITY ACT 2024 CHAPTER 272 (“The Act”), the owner of a Critical Information Infrastructure (“CII”) must, starting from the date of the notice issued under section 9 (Designation of CII), cause an audit of the compliance of the Critical Information Infrastructure with the Act and applicable codes of practice¹ and standards of performance². The cybersecurity audit must be carried out at least once every 2 years (or at such higher frequency as may be directed by the Commissioner in any case), and to be carried out by an auditor approved or appointed by the Commissioner.

At least once a year, starting from the date of the notice issued to conduct a cybersecurity risk assessment of the critical information infrastructure in such form and manner as the Commissioner may determine.

1.1 Importance of Cybersecurity Risk Assessment

With rapid advancement in technology, shifting cyber threat landscape and increased digitalisation, organisations may be exposing themselves to greater cybersecurity risks that may potentially have an adverse impact to their organisation and business objectives. Thus, it is imperative for organisations to manage these cybersecurity risks effectively. Cybersecurity risk assessment (referred to as “risk assessment”) is an integral part of an organisation’s enterprise risk management process. By conducting a risk assessment, organisations would be able to:

- Identify “what could go wrong” events that are often a result of malicious acts by threat actors and could lead to undesired business consequences.
- Determine the levels of cybersecurity risk that they are exposed to. A good understanding of the risk levels would allow an organisation to dedicate adequate action and resources to treat risks of the highest priority.
- Create a risk-aware culture within the organisation. Risk assessment is an iterative process that involves engaging employees to think about technology risks and how they align to business objectives.

1.2 Common Problems Observed

While organisations recognise that risk assessment is an important part of their enterprise risk assessment practice, many struggled with the process to conduct a proper risk assessment. Some of the common gaps observed include the following:

- **Poor articulation of risk scenarios** – Risk scenarios describing “what could go wrong” events were often vague and generic without articulating specific threat events, vulnerabilities, assets, and consequences. As a result, it is difficult to understand the extent of the risks, relate them to the organisational context, or identify targeted measures to address the risks.
- **Identification of risks using a compliance-oriented approach** – Many organisations identify risks from the point of assessing security controls (or lack thereof), like performing a compliance audit or gap analysis against a set of defined standards. A compliance-oriented approach towards risk assessment drives a “checklist” behaviour, giving a false sense of security that an organisation is not exposed to any risks as long as they fulfil all compliance requirements.

¹ Code of Practice means any code of practice issued or approved under section 13(1);

² Standard of Performance means any standard of performance issued or approved under section 13(1);

- **Absence of risk tolerance** – Organisations often do not integrate their cybersecurity risk management plans into their enterprise risk management programme. As a result, cybersecurity risk tolerance at the enterprise level is often ignored, and management face difficulty in deciding the appropriate level of risk-taking to adopt whilst in pursuit of their organisation's business objectives.
- **Determining risk likelihood based on historical or expected occurrences** – Organisations have traditionally used the measure of time/frequency (e.g., historical or expected occurrences of events) to estimate their risk likelihood. The approach may be inaccurate when it is based on the number of times an incident has occurred previously, especially when there is lack of information on past cybersecurity incidents. In the context of cybersecurity, the likelihood of a cybersecurity incident is independent of the frequency of past occurrence.
- **Treating risks with irrelevant controls/measures** – Organisations may take a broad approach in coming up with measures to mitigate identified cybersecurity risks, resulting in the implementation of controls that do not fully address the root cause. This often stems from a poor understanding or articulation of risk scenarios.

2 PURPOSE, AUDIENCE & SCOPE

2.1 Purpose of Document

The purpose of this document is to set the audit expectations, and to serve as a guide for approved or appointed auditors by the Commissioner to conduct cybersecurity audit of CII and to provide guidance to Critical Information Infrastructure Owners (CIIOs) on how to perform a proper cybersecurity risk assessment.

This document is not meant to be an exhaustive source of information for conducting a CII cybersecurity audit. In the absence of any cybersecurity audit topics not covered in this guide, the auditor should exercise their professional judgement and highlight such situation in the audit report.

This document will also identify expectations that are required of CIIOs to take note when performing their risk assessment. The expectations are denoted with the icon below in this guidance document.



2.2 Audience

The intended audience of this document is meant for use by both internal and external stakeholders but not limited to, the following:

- a) Auditors who have been formally approved or appointed by the Commissioner; and
- b) Stakeholders (E.g., business unit heads, system owners and vendor, Chief Information Security Officers, etc.) within any organisations, including CIIOs.
- c) External consultants or service providers conducting risk assessment on behalf of organisations.

2.3 Scope

This document covers the following cybersecurity audits and risk assessment:

- a) The cybersecurity audit and risk assessment under the Act. Refer to Section 17: Cybersecurity audits and risk assessments of critical information infrastructure; and
- b) The risk assessment focuses only on the areas of risk framing, assessment, and treatment. Other areas such as risk monitoring and reporting, which comes under a wider domain of risk management, is beyond the scope of this guidance.

3 AUDITOR APPROVAL

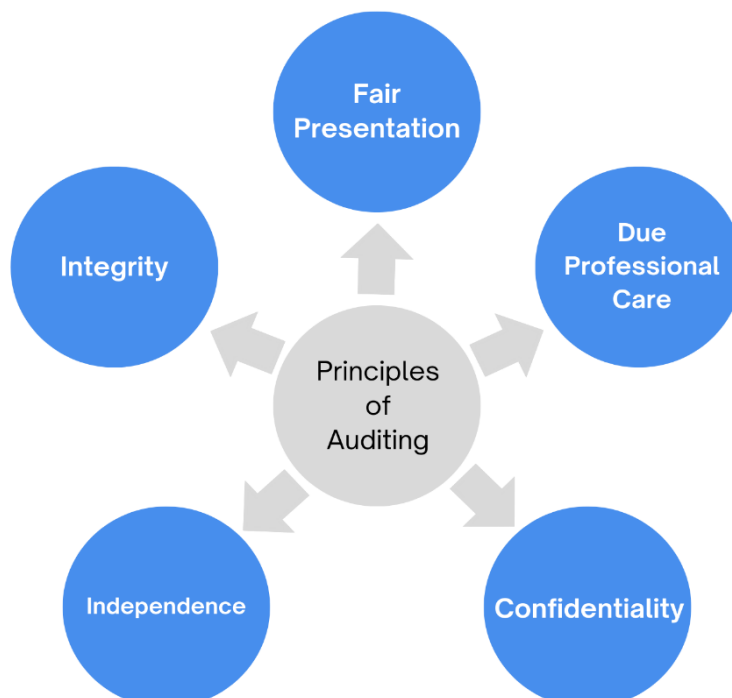
Auditors must be approved or appointed by the Commissioner to conduct cybersecurity audit on the CII. To complete the application for Commissioner's approval, both the CIIOs and auditors are required to submit the relevant forms as specified by CSB. While the auditors can directly submit the applicable form to CSB, the application would only be deemed complete after all the relevant forms and accompanying documents submitted by the CIIOs and auditors are complete and in order.

There are two main criteria, i.e., independence and competency, that the proposed audit firm/team and auditors need to fulfil. The appointed audit firm/team and auditors:

- a) Should not be in a position of any conflict of interest, whether actual, potential, or perceived. A conflict of interest refers to any circumstance where the auditor's interests may potentially interfere with the independent and objective performance of his/her duties as an auditor; and
- b) Should possess the necessary technical competencies (i.e., professional qualifications/certifications, skills, knowledge, and relevant experiences) to perform the audits.

4 AUDIT EXPECTATION

This section sets out CSB's audit expectations. It is intended to help the reader understand how cybersecurity audit should be conducted and reported. CSB has listed down seven areas of audit expectations in sections 4.1 to 4.7.



4.1 Principle of Auditing

Audits should adhere to the following principles for providing relevant and sufficient audit conclusion. This is to enable auditors, working independently, to reach similar conclusions in similar circumstances.

- a) **Integrity:** The foundation of professionalism.
 - Perform audits with honesty and responsibility.
 - Ensure competence while performing audits.
 - Perform audits in an impartial manner.
 - Ensure fair and unbiased in all dealings. Be sensitive to any influences that may be exerted on auditor's judgement during an audit.
- b) **Fair Presentation:** The obligation to report truthfully and accurately.
 - Ensure audit findings, audit conclusions and audit reports reflect truthfully and accurately the audit activities.
 - Report significant obstacles encountered during audit and unresolved diverging opinions between the audit team and the auditee.
 - Ensure the communication is truthful, accurate, objective, timely, clear, and complete.
- c) **Due Professional Care:** the application of diligence and judgement in auditing.
 - Exercise due care in accordance with the importance of the task and the confidence placed in auditor by the audit client and other interested parties.
 - Make reasoned judgements in all audit situations.
- d) **Confidentiality:** Security of information.
 - Exercise discretion in the use and protection of information obtained during audit.
 - Do not use the audit information for personal gain or in detrimental way to the legitimate interests of the auditee.
 - Handle sensitive or confidential information properly.
- e) **Independence:** The basis for the impartiality of the audit and objectivity of the audit conclusions.
 - Ensure independence of the activity being audited.
 - Act in a manner that is free from bias and conflict of interest in all cases.
 - Maintain objectivity throughout the audit process.
 - Ensure the audit findings and conclusions are based only on the audit evidence.

4.2 Audit Objective

The objective of the audit is to:

- a) Verify the compliance of CII against requirements stipulated in Part 17 of the Act, including the subsidiary legislation, applicable written directions, Code of Practice and Standard of performance; and
- b) Assess the adequacy and effectiveness of controls/measures put in place to meet the requirements stipulated in Part 3 of the Act, including the subsidiary legislation, applicable written directions, Code of Practice and Standard of performance.

4.3 Audit Scope

The audit shall cover the following:

Scope	Description
Audit Scope	The audit subject should cover all CII that has been designated under the Act.
Audit Period	The audit period should minimally be 12 months and there should be no gap between the audit periods for each CII.
Audit Criteria	The audit criteria should include compliance with the Act, subsidiary legislation, applicable written directions, Code of Practice and Standard of performance.

4.4 Audit Approach

The audit should adopt both a compliance and risk-based approach.

a) Compliance-based

Carry out compliance test to ascertain the adequacy and effectiveness of the controls applied in the CII to comply with the Act, subsidiary legislations, applicable written directions, Code of Practice, and Standard of Performances.

b) Risk-based

Identify the risks and threats that the CII faces and ascertain if the controls put in place are appropriate to mitigate the known risks and threats.

4.5 Audit Finding

The auditor should highlight the following:

- Any audit finding identified during the audit;
- Highlight systemic finding, where the finding is spread throughout the CII, which could likely be a weakness in the design of the control;
- Highlight recurring finding, i.e., finding brought up from past audits that have reoccurred in the current audit even after implementing the corrective action; and
- Highlight good practices, in areas of governance and controls, noted during the audit.

When raising an audit finding, the auditor should clearly articulate the following attributes of the audit finding.

ATTRIBUTES	DESCRIPTION
Condition	Statement that describes the results of the audit finding.
Criteria	Standards/ Rules/ Benchmarks (e.g., Cybersecurity Act, policies, and best practices) used to measure against the condition.
Cause	The root cause and contributory reason(s) for the condition.
Effect	The effect and significance of the condition (Immediate, future, or potential). The auditor should associate the audit finding to the impact on CII's essential services in which the management is familiar with, i.e., quantitative effect (e.g., cost, time and production) and qualitative effect (e.g., service and poor decision-making). This helps to convince the management on the need for corrective action
Recommendation	Recommend action(s) to correct the cause to prevent the reoccurrence of the audit finding

4.6 Audit Conclusion

The auditor should give their opinion and conclusion on the following areas:

- Appropriateness of the management comments in response to the audit finding;
- Adequacy and effectiveness of the controls put in place by the CII to address cybersecurity risks to the CII; and
- Opportunities for improvement to secure the CII.

4.7 Audit Report Format

The audit report should minimally contain the following:

CONTENT	DESCRIPTION
Executive Summary	The report should offer an overall assessment of findings, including issues, risks and potential implications on the CII, recommendations, management feedback, and the auditor's assessment on the management feedback. The executive summary should include the auditors conclude on control effectiveness against cybersecurity risks.
Purpose	The report should explain the reason for the cybersecurity audit (e.g., to fulfil Cybersecurity Act obligations or Commissioner's directives)
Audit Objective	Audit objective is defined in section 4.2
Audit Scope	Audit scope is defined in section 4.3
Stakeholders	The stakeholders involved in the cybersecurity audit, their roles and responsibilities should clearly be stated
Audit Methodology and Approach	The report should explain how the cybersecurity audit achieved its objectives; the explanation should state: a. If work of other auditors (e.g., past auditors) was used and how extensively reliance was made. b. The type of analysis methods used (e.g., interviews, walkthroughs, document reviews) c. Sampling methods used if assessing control effectiveness through samples.
Audit Finding	Audit finding is defined in section 4.5
Audit Conclusion	Audit conclusion is defined in section 4.6

5 ESTABLISH RISK CONTEXT

Establishing risk context is an important pre-requisite for conducting risk assessment. This step ensures that internal and external stakeholders involved in the risk assessment exercise have a common understanding of how the risk is framed, the risk tolerance to consider and the responsibilities of the risk owner.

5.1 Define Risk

There are many definitions of cybersecurity risk. Hence, before going further into the details of conducting a risk assessment, it is important to establish a common definition of cybersecurity risk. For this guidance document, risk is defined as the function³ of:

- The likelihood of a given threat event exercising on a vulnerability of an asset; and
- The resulting impact of the occurrence of the threat event

$$\text{Risk} = \text{Function} (\text{Likelihood}, \text{Impact})$$

Each of the risk factors mentioned in the definition is explained below.

Threat Event

Threat event refers to any event during which a threat actor⁴, by means of threat vector⁵, acts against an asset in a manner that has the potential to cause harm. In the context of cybersecurity, threat events can be characterised by the tactics, techniques, and procedures (TTP) employed by threat actors.

Vulnerability

Vulnerability refers to a weakness in the design, implementation and operation of an asset, or the internal control of a process.

Likelihood

Likelihood refers to the probability that a given threat event is capable of exploiting a given vulnerability (or set of vulnerabilities). The probability can be derived based on factors namely, discoverability, exploitability, and reproducibility.

Impact

Impact refers to the magnitude of harm resulting from a threat event exploiting a vulnerability (or set of vulnerabilities). The magnitude of harm can be estimated from the perspective of a nation, organisation, or individual.

³ The function of risk is adapted from National Institute of Standards and Technology Special Publication 800-30 Revision 1 (NIST SP 800-30R1)

⁴ Threat actor refers to a person or entity that is responsible for an event that has the potential to cause harm.

⁵ Threat vector refers to the path or route that a threat actor uses to attack a target

5.2 Determine Risk Tolerance

Risk tolerance⁶ is defined as the level of risk taking acceptable to achieve a specific business objective. Determining risk tolerance allows the Management to articulate how much risk the organisation is willing to accept.

A well-defined risk tolerance should articulate:

- Expectations for treating and pursuing specific types of risk
- Boundaries and thresholds of acceptable risk taking

Figure 1 below is an example of a risk tolerance table and must be tailored according to each organisation's context.

Risk Level	Risk Tolerance Description
Very High	This level of risk cannot be accepted and would create an impact so severe that the related activity would need to cease immediately. Alternatively, mitigation or transference strategies need to be taken immediately.
High	This level of risk cannot be accepted. Treatment strategies aimed at reducing the risk level should be developed and implemented in the next 1 month.
Medium High	This level of risk cannot be accepted. Treatment strategies aimed at reducing the risk level should be developed and implemented in the next 3-6 months.
Medium	This level of risk can be accepted if there are no treatment strategies that can be easily and economically implemented. The risk must be regularly monitored to ensure that any change in circumstance is detected and acted upon appropriately
Low	This level of risk can be accepted if there are no treatment strategies that can be easily and economically implemented. The risk must be periodically monitored to ensure that any change in circumstances is detected and acted upon appropriately.

Figure 1: An example of how risk tolerance is represented

	CIIOs to note: In the CII risk assessment report, risk tolerance levels must be clearly defined.
---	--

⁶ Sources such as ISACA define risk tolerance as “the acceptable level of variation that management is willing to allow for any particular risk as the enterprise pursue its objectives”, and use the term risk appetite to refer to “the amount of risk, on a broad level, that an entity is willing to accept in pursuit of its mission”. This guidance document does not distinguish between risk tolerance and risk appetite as we view them both to broadly mean the same (i.e., how much risk an organisation is willing to accept).

5.3 Define Roles and Responsibilities

To ensure that stakeholders are aware of their expected roles in a risk assessment exercise, it is important to state them clearly upfront. Key roles in a risk assessment exercise include:

Head of Organisation

Highest-level senior official within the organisation with the overall responsibility and accountability for ensuring risks are appropriately managed within the organisation's tolerance level, and accepting all residual risks.

Business Owner

Highest-level senior official of a business unit responsible for ensuring that business activities meet business goals, or share concerns on the impact of system disruptions to the business.

Risk Management Function

An individual or group within the organisation responsible for the organisation-wide risk management approach. They should serve as a bridge between the technical and business function during risk assessment process, and provide oversight of the risk assessment activities to ensure consistent risk-based decisions.

Technology and Operations Function

An individual or group within the organisation that is responsible for the maintenance and operations of the technological infrastructure, including network and applications, to support the running of the system(s) supporting business activities. They should know the system assets and technical operations very well, and be able to advise on the technical impact for a compromised system.

Cybersecurity Function

An individual or group within the organisation responsible for the implementation and maintenance of cybersecurity controls in system(s) supporting business activities. They should identify the potential threats to a system, conceptualise cybersecurity risk scenarios, determine risk likelihood, as well as advise the appropriate measures to address the identified threats/attacks.



CIIOs to note:

In the CII risk assessment report, the stakeholders' roles and responsibilities in the risk assessment exercise must be clearly specified.

6 CONDUCT RISK ASSESSMENT

Risk assessment is about identifying risks that are specific to the environment, and determining the level of identified risks. The main steps in a risk assessment are risk identification, risk analysis and risk evaluation.



Figure 2: Process for Conducting Risk Assessment

6.1 Step 1: Risk Identification

Task A: Identify Assets

As the old security adage goes, “You can’t protect what you don’t know.” Therefore, the first task is to identify and create an inventory of all physical and logical assets that make up the system that is within the risk assessment scope. When identifying the assets, it is important to take note of those that are:

- **Crown jewels** - These assets are critical to achieving the overall business objectives and are usually what the attackers would actively seek to exploit
- **Stepping stones** - These assets are resources that attackers would want to take control and leverage to pivot across network segments before reaching the crown jewels.

Use the asset inventory list consolidated to create a network architecture diagram that provides a visual representation of the interconnectivity and communication paths between the assets.

Identify and label all entry points (i.e., attack vectors) into the system, as well as the stepping stones and crown jewels. This would help facilitate the next task to identify threats.

Task B: Threat Modelling

With the asset inventory list and network architecture diagram, the threat events that could exploit the vulnerabilities for each asset should be identified for deeper analysis. One of the techniques that organisations should employ is threat modelling. Threat modelling is a structured process for identifying threat events that are pertinent to the system, so that organisations can build a more focused defence to protect the system. Threat modelling entails the following steps:

- **Scope Identification and System Decomposition** – These are the prerequisites for threat modelling that were introduced in Task A.
- **Threat Identification** – Next, organisations should adopt a systematic approach to identify the possible events where attackers can compromise the assets.
- **Attack Modelling** – After identifying the threat events relevant to each asset, organisations should link them into a possible sequence of attack. Attack modelling describes an attacker’s intrusion approach so that organisations can identify controls needed to defend the system and prioritise their implementation.

For more information on threat modelling, refer to the “Guideline to Cyber Threat Modelling”⁷ that CSB has published.

Task C: Construct Risk Scenarios

Constructing risk scenarios is the last task to complete the Risk Identification Step. This task aims to create “what could go wrong” scenarios that provide realistic and relatable view of risks based on the business context, system environment and pertinent threats.

A well-constructed risk scenario facilitates communication to stakeholders and allows for structured analysis of risks in subsequent steps. A risk scenario should articulate the following four (4) key elements:

- **Asset** - An object of value that has been identified in Task A.
- **Threat event** - An attack event that has been identified in Task B.
- **Vulnerability** - A weakness in the asset or processes supporting the asset that can be exploited by the identified threat event. The vulnerability may have surfaced in recent audits and/or penetration-tests, or may be relevant to the environment due to the use of certain technologies.
- **Consequence**⁸ - The direct result of the threat event.

⁷ The Guideline to Cyber Threat Modelling can assist system owners in identifying and addressing potential threats, allowing them to implement effective controls and safeguard key components.

⁸ The terms “consequence” and “impact” are often used interchangeably. However, they have different meanings and must not be confused. While “consequence” is the direct result of a threat event (e.g., power outage, disruption of services, loss of confidential data), “impact” is the degree to which consequence affects the business, operations etc (i.e., magnitude of harm)

Some examples of well-constructed risk scenarios are illustrated below.

Legend: Threat Event | Vulnerability | Asset | Consequence

Attacker performs an SQL injection on an unpatched legacy web application to download sensitive patient medical records.

Example 1: Risk Scenario

Internal staff makes a fraudulent payment instruction exceeding bank account balance on the payment system with no set limit, resulting in a bank overdraft.

Example 2: Risk Scenario

Unauthorised employee accesses the SCADA server using default login credentials and execute shutdown command to disrupt the water supply to the entire Brunei Muara district.

Example 3: Risk Scenario

Attacker delivers spear-phishing email to unsuspecting user, which when clicked, triggers the user account to perform SMB authentication with malicious server and discloses hashed credentials.

Example 4: Risk Scenario



CIIOs to note:

In the CII risk assessment report, risk scenarios must include elements of threat event, vulnerability, asset, and consequence.

6.2 Step 2: Risk Analysis

Risk analysis is about analysing the elements that make up each risk scenario to determine:

- The likelihood of a risk scenario occurring; and
- The impact (i.e., magnitude of harm) resulting from the occurrence of a risk scenario

Task A: Determine Likelihood

Historical or expected occurrence of an event has traditionally been used as a metric to measure the risk likelihood (e.g., Event is expected to occur once every year or has occurred once in the past year). However, the use of such a metric to measure cybersecurity risk likelihood may not be appropriate due to the dynamic nature of cybersecurity threats. A system that has not been compromised previously does not mean it would not be compromised in the future.

As a general guidance, the likelihood of cybersecurity risks should be assessed from the perspective of threats and vulnerabilities. One method to determine the cybersecurity risk likelihood is to consider the following factors⁹:

- **Discoverability** - How easy would an adversary be able to discover the vulnerability of an asset? This is dependent on the availability of information about the vulnerability and the exposure of the vulnerable asset.
- **Exploitability** - How easy would an adversary exploit the vulnerability of an asset? This is dependent on the access rights, complexity of tools, as well as technical skills required to carry out the attack.
- **Reproducibility** - How easy would an adversary be able to reproduce the attack on the asset? This is dependent on the complexity of the exploit customisation and the environmental conditions required to carry out the attack.

Figure 3 below is a sample assessment table to determine the cybersecurity risk likelihood based on the factors described above. The following steps can be taken to derive the likelihood score of a cybersecurity risk scenario:

- Assign a score for each of the 3 likelihood factors (i.e., 1 – 5)
- Average the score and round off to the nearest whole number
- The final score will be the likelihood of the risk scenario; 5 being “Highly Likely” and 1 being “Rare”

⁹ The factor (Discoverability, Exploitability and Reproducibility) is adapted from Microsoft’s DREAD model for threat assessment.

Likelihood Rating	Discoverability	Exploitability	Reproducibility
Highly Likely (5)	The vulnerability of the target: - can be discovered by searching / scanning the public domain for published information (e.g., Shodan, Exploit DB); - can be discovered and attacked from external networks (including the internet)	The attack: - can be performed with no access rights of the target; - can be performed with publicly available tools without technical knowledge	The attack: - can be repeated at will without any specific configuration⁸ or event condition⁹; - can be repeated at will without any customisation of the published exploits
Likely (4)	The vulnerability of the target: - can be discovered by probing the target (e.g., ports scans); - can be discovered and attacked from adjacent subnets or network segments	The attack: - can be performed with restricted access rights of the target (e.g., user); - can be performed with publicly available tools with basic technical knowledge	The attack: - can be repeated given certain configuration in the target; - can be repeated with minimal customisation of the published exploits (e.g., change of parameters)
Possible (3)	The vulnerability of the target: - can be discovered by examining the target's responses, behaviour, and communication (e.g., fuzzing with networks packets, network sniffing); - can be discovered and attacked from within the same subnet or network segment	The attack: - can be performed with privilege access rights of the targets (e.g., admin/SYSTEM/root); - can be performed with publicly available tools that requires moderate technical knowledge	The attack: - can be repeated given certain predictable event condition; - can be repeated with customisation specific for the target
Unlikely (2)	The vulnerability of the target: - can be discovered by operating and interacting with the actual or similar setup of the target; - can be discovered and attacked with logical local access	The attack: - can be performed with privilege access rights of the targets (e.g., admin/SYSTEM/root); - can be performed with publicly available /specialise tools that requires advance technical knowledge; - may requires chaining of multiple exploits	The attack: - can be repeated given certain random event condition; - can be repeated theoretically or with published proof of concept exploit

Likelihood Rating	Discoverability	Exploitability	Reproducibility
Rare (1)	The vulnerability of the target: - can be discovered by studying the blueprint (e.g., source code); - can be discovered and attacked with physical access	The attack: - can be performed with privilege access rights of the targets (e.g., admin/root/SYSTEM) and required multi-factor authentication; - can be performed with specialised tools that requires expert technical knowledge; - may requires chaining of multiple exploits	The attack: - cannot be reproduced on the target; - can be repeated with unpublished exploit specific for the target

Figure 3: A sample assessment table for determining risk likelihood

	CIIOs to note: In the CII risk assessment report, - The risk likelihood must be scored along the scale of 1 to 5 (i.e., 1 being “rare” and 5 being “highly likely”)¹⁰. - The risk likelihood must be determined based on threat and vulnerability. - The likelihood factors (i.e., Discoverability, Exploitability, and Reproducibility) are recommended for use to determine the risk likelihood.
---	--

¹⁰ Consistency in the use of risk likelihood scale is necessary, so that CII risks can be aggregated and viewed at the national level.

Task B: Determine Impact

In general, the manifestation of a risk scenario can compromise the confidentiality, integrity and/or availability of assets (e.g., data, equipment, operations). Any compromise of the assets will translate to adverse impact at the following three (3) levels:

- **National** – At the national level, the impact can be viewed as harm to national security and economy.
- **Organisational** – At the organisational level, the impact can be viewed as disruption to business operations, damage to reputation and loss of financials.
- **Individual** - At the individual level, the impact can be viewed as loss of life and injuries.

Figure 4 below is a sample assessment table for determining the risk impact on a rating scale of 1 to 5 (5 being “Very Severe” and 1 being “Negligible”). The descriptors provided in the sample table below are generic. When adopting a similar impact table, organisations should review and tailor the descriptors for each impact rating to ensure they are:

- **Relevant to business context** - Link descriptors to the organisation’s business objectives or performance measures.
- **Unambiguous** - Use descriptors that are binary or with quantitative ranges (e.g., leakage of data classified as “Confidential,” disruption of services to more than 50% of customers)
- **Multi-perspectives** - Identify sub-categories of impact from each of the 3 levels (i.e., national, organisational, and individual)

Impact Rating	Confidentiality	Integrity	Availability
Very Severe (5)	The unauthorised disclosure of information could be expected to have an exceptionally grave adverse effect on organisation, individuals, or the nation.	The unauthorised modification or destruction of information could be expected to have an exceptionally grave adverse effect on organisation, individuals, or the nation.	The disruption of access to or use of information or computer system could be expected to have an exceptionally grave adverse effect on organisation, individuals, or the nation.
Severe (4)	The unauthorised disclosure of information could be expected to have a serious adverse effect on organisation, individuals, or the nation	The unauthorised modification or destruction of information could be expected to have a serious adverse effect on organisation, individuals, or the nation.	The disruption of access to or use of information or computer system could be expected to have a serious adverse effect on organisation, individuals, or the nation.

Impact Rating	Confidentiality	Integrity	Availability
Moderate (3)	The unauthorised disclosure of information could be expected to have some adverse effect on organisation, individuals, or the nation.	The unauthorised modification or destruction of information could be expected to have some adverse effect on organisation, individuals, or the nation	The disruption of access to or use of information or computer system could be expected to have some adverse effect on organisation, individuals, or the nation.
Minor (2)	The unauthorised disclosure of information could be expected to have a limited adverse effect on organisation, or individuals	The unauthorised modification or destruction of information could be expected to have a limited adverse effect on organisation, or individuals.	The disruption of access to or use of information or computer system could be expected to have a limited adverse effect on organisation, or individuals.
Negligible (1)	The unauthorised disclosure of information could be expected to have negligible effect on organisation, or individuals.	The unauthorised modification or destruction of information could be expected to have negligible effect on organisation, or individuals.	The disruption of access to or use of information or computer system could be expected to have negligible effect on organisation, or individuals.

Figure 4: Generic descriptors for determining impact of risk

	CIIOs to note: In the CII risk assessment report, - The risk impact must be scored along the scale of 1 to 5 (1 being “negligible” and 5 being “very severe”)¹¹. - The descriptors for each impact rating must be tailored to respective organisational context.
---	---

¹¹ Consistency in the use of risk impact scale is necessary, so that CII risk can be aggregated and views at the nation level.

6.3 Step 3: Risk Evaluation

Risk evaluation is about determining and understanding the significance of risk level, and comprises the following tasks:

- Determine and prioritise risk
- Document risk

Task A: Determine and Prioritise Risk

As mentioned in Chapter 5, risk is a function of the likelihood of a given threat event exploiting a potential vulnerability of an asset, and resulting impact. This can be diagrammatically presented using a risk matrix. Figure 5 below is a sample 5-by-5 risk matrix for determining risk level for each risk scenario, where risk level is a multiplication of “Likelihood” and “Impact” determined from the Risk Analysis step (Section 4.2).

IMPACT	Very Severe (5)	Medium (5)	Medium High (10)	High (15)	Very High (20)	Very High (25)
	Severe (4)	Low (4)	Medium (8)	Medium High (12)	High (16)	Very High (20)
	Moderate (3)	Low (3)	Medium (6)	Medium (9)	Medium High (12)	High (15)
	Minor (2)	Low (2)	Low (4)	Medium (6)	Medium (8)	Medium High (10)
	Negligible (1)	Low (1)	Low (2)	Low (3)	Low (4)	Medium (5)
		Rare (1)	Unlikely (2)	Possible (3)	Likely (4)	Highly Likely (5)
		LIKELIHOOD				

Figure 5: A 5-by-5 Risk Matrix for determining risk level

For each risk level derived, compare it against the risk tolerance level defined by the organisation. Risk scenarios with risk levels above the tolerance level must be prioritised for treatment until the risk levels fall to within the tolerance level. When prioritising risk for treatment, the expected duration should also be established.

	CIIOs to note: In the CII risk assessment report, the risk level must be determined using a 5-by-5 matrix ¹² .
---	---

¹² Consistency in the use of risk matrix is necessary, so that CII risks can be aggregated and viewed at the national level.

Task B: Document Risk

A risk assessment is incomplete without documentation. The outputs from previous steps must be clearly documented in a Risk Register for communication to stakeholders. A Risk Register is a record of all the risk scenarios identified, including their determined risk level. The Risk Register is a living document to be regularly reviewed and updated to ensure that the organisation's management has an up-to-date picture of the organisation's cybersecurity risks when making risk-informed decisions. It should minimally contain the following:

- **Risk scenario** – A scenario articulating how a threat event could exploit a potential vulnerability of an asset to create an adverse impact.
- **Identification date** – The date when the risk scenario is identified.
- **Existing measures** – The current measures in place to address the risk scenario.
- **Current risk** – The determined risk level (combination of likelihood and impact) of risk scenario after considering existing measures (i.e., inherent risk¹³ with existing measures applied).
- **Treatment plan** – The planned activities (e.g., deploying additional measures) and timeline to treat the current risk to an acceptable level (i.e., within organisation's risk tolerance level).
- **Progress Status** – The status of implementing the treatment plan.
- **Residual risk** – The determined risk level (combination of likelihood and impact) of risk scenario after treatment plan is implemented (i.e., current risk with additional measures applied).
- **Risk Owner** – The individual or group responsible for ensuring that the residual risks remain within the organisation's tolerance level.



CIIOs to note:

In the CII risk assessment report, the Risk Register must minimally include the eight (8) elements, namely risk scenario, identification date, existing measures, current risk, treatment plan, progress status, residual risk, risk owner.

¹³ Inherent risk refers to risk level without considering any measures.

7 RESPOND TO RISKS

Having evaluated the identified risks (i.e., current risks), the next step is to identify and determine the next course of action to keep the risks within the organisation's risk tolerance level.

7.1 Types of Risk Response Options

There are four (4) risk response options to consider:

Accept

Risk acceptance means undertaking risk as it is without introducing further actions to reduce it. Risk should only be accepted when it falls within the organisation's tolerance level.

Avoid

Risk avoidance means discontinuing an action/activity that exposes the organisation to the identified risk. This may appear extreme but may be the best course of action if the risk outweighs the benefits.

Transfer

Risk transference means sharing a portion of risk with other parties or entities. Such a treatment option typically reduces the "impact" component of risk.

Mitigate

Risk mitigation means putting in place measures to reduce the risk level. This can be achieved through the deployment of security controls.

Whichever risk response option is taken, senior management (with the appropriate level of authority and accountability) within the organisation must formally approve the selected risk response and make a conscious decision to accept the residual risks.

7.2 Choosing the Appropriate Risk Response Actions

Many organisations tend to treat risks through mitigation by investing in costly security controls and technical solutions. However, organisations should also explore treating risks through avoidance or transference as possible alternatives that may also be cost-effective. For example, to address the risk of system compromise when employees access malicious websites, organisations may want to consider avoiding the risk by removing internet-surfing capabilities instead of mitigating the risk through deployment of expensive end-point preventive solutions.

When organisations choose to treat risks through mitigation, they need to ensure that the security controls they implement are relevant and appropriate to the risks they are addressing. As a general guidance, a control is considered appropriate and relevant to a risk when it:

- Reduces risk likelihood; or
- Reduces risk impact



CIIOs to note:

In the CII risk assessment report,

- Senior Management must formally approve all treatment plans.
- Senior Management must formally approve accept all residual risks.

8 TERMS AND DEFINITIONS

For the purpose of this document, the following terms and definitions apply.

Term	Definitions
Audit	The systematic, independent, and documented process for obtaining audit evidence (8.3) and evaluating objectively to determine the extent to which the audit criteria (8.2) are fulfilled.
Audit criteria	A set of requirements used as a reference against which audit evidence (8.3) is compared.
Audit evidence	Audit evidence refers to records, statements of fact or other information, which are relevant to the audit criteria (8.2) and verifiable
Audit finding	An audit criterion not being met
Audit period	The period to which the audit work relates and from which audit evidence is obtained.
Audit subject	Audit subject refers to the CII system that is to be audited.
Adequacy of control	Adequacy refers to whether the control in place is fit for the purpose.
Compensating control	Compensating control, also called an alternative control, may be considered when an entity cannot meet a requirement explicitly as stated, due to legitimate technical or documented business constraints, but has sufficiently mitigated the risk associated with the requirement through implementation of other controls. Compensating control must: a. Meet the intent and rigor of the original requirement; b. Provide a similar level of defence as the original requirement; and Commensurate with the additional risk imposed by not adhering to the requirement.
Effectiveness of control	Effectiveness refers to whether the control in place has the desired effect of mitigating the risk.
Interim control	A set of measures designed to reduce the risk temporarily while the recommended control is being implemented

ANNEX

Summary of Expectations for CIIOs

 CIIOs to note:	Related Section
In the CII risk assessment report, risk tolerance levels must be clearly defined	5.2
In the CII risk assessment report, the stakeholders' roles and responsibilities in the risk assessment exercise must be clearly specified.	5.3
In the CII risk assessment report, risk scenarios must include elements of threat event, vulnerability, asset, and consequence.	6.1
In the CII risk assessment report, • The risk likelihood must be scored along the scale of 1 to 5 (i.e., 1 being “rare” and 5 being “highly likely”). • The risk likelihood must be determined based on threat and vulnerability. • The likelihood factors (i.e., Discoverability, Exploitability, and Reproducibility) are recommended for use to determine the risk likelihood.	6.2 [Task A]
In the CII risk assessment report, • The risk impact must be scored along the scale of 1 to 5 (1 being “negligible” and 5 being “very severe”). The descriptors for each impact rating must be tailored to respective organisational context	6.2 [Task B]
In the CII risk assessment report, the risk level must be determined using a 5- by-5 matrix.	6.3 [Task A]
In the CII risk assessment report, the Risk Register must minimally include the eight (8) elements, namely risk scenario, identification date, existing measures, current risk, treatment plan, progress status, residual risk, risk owner.	6.3 [Task B]
In the CII risk assessment report, • Senior Management must formally approve all treatment plans. • Senior Management must formally accept all residual risks.	7.2

REFERENCES

- [1] ISO 19011:2018(E), “Guidelines for auditing management systems,” ISO, 2018.
- [2] PCI Security Standards Council, “PCI DSS and PA-DSS Glossary of Terms, Abbreviations, and Acronyms,” April 2016. [Online]. Available: https://www.pcisecuritystandards.org/documents/PCI_DSS_Glossary_v3-2.pdf?agreement=true&time=1577691345202. [Accessed 18 April 2024].
- [3] ISACA IT Standards, Guidelines, and Tools and Techniques for Audit and Assurance and Control Professionalism, ISACA, 2010.
- [4] ISACA Information Systems Auditing: Tools and Techniques - Creating Audit Program, ISACA, 2016.
- [5] J. T. Langill and E. D. Knapp, Industrial Network Security, Second Edition: Securing Critical Infrastructure Networks for Smart Grid, SCADA, and Other Industrial Control Systems, Elsevier, 2014.
- [6] C. E. Bodungen, B. L. Singer, A. Shbeeb, S. Hilt and K. Wilhoit, Industrial Control Systems Hacking Exposed, McGraw-Hill Education, 2017.
- [7] (NIST), National Institute of Standards and Technology, “Managing Information Security Risk: Organization, Mission, and Information System View,” March 2011. [Online]. Available: <https://csrc.nist.gov/publications/detail/sp/800-39/final>. [Accessed 18 April 2024].
- [8] ISACA, CRISC Review Manual 6th Edition, ISACA, 2015.
- [9] A. Shostack, Threat Modeling: Designing for Security, John Wiley & Sons Inc., 2014.
- [10] (NIST), National Institute of Standards and Technology, “Guide for Conducting Risk Assessments,” September 2012. [Online]. Available: <https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final>. [Accessed 18 April 2024].